

MID-STATE TECHNICAL COLLEGE • IT PROGRAMS

Social Engineering: Physical Attacks

Unit 6 • Ethical Hacking (10-151-160)



Learning Outcomes

By the end of this unit, you will be able to:



Recognize social engineering methods

Spot impersonation, pretexting, eavesdropping, shoulder surfing, dumpster diving, and vishing.



Build and test a pretext

Construct a believable cover story and stress-test it against a partner's questions.



Survey physical and network tools

Describe lock-picking gear and Hak5 implants used once an attacker has physical access.



Explain rogue USB attacks

Explain how keystroke-injection devices abuse a computer's trust in keyboards.



Defend and mitigate

Apply individual response tactics and recommend layered physical controls.



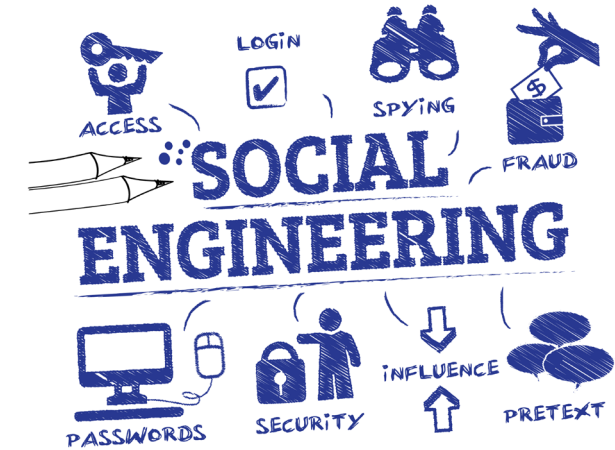
LESSON 1

Social Engineering Foundations

What Is Social Engineering?

The manipulation of people into actions that compromise security — the goals fall into a few buckets:

- **Information gathering** — names, schedules, badge designs, internal jargon.
- **Fraud** — approving a payment, transfer, or purchase under false pretenses.
- **System access** — talking or tricking a way onto a network or account.
- **Physical access** — getting past doors, badges, and locks into restricted space.

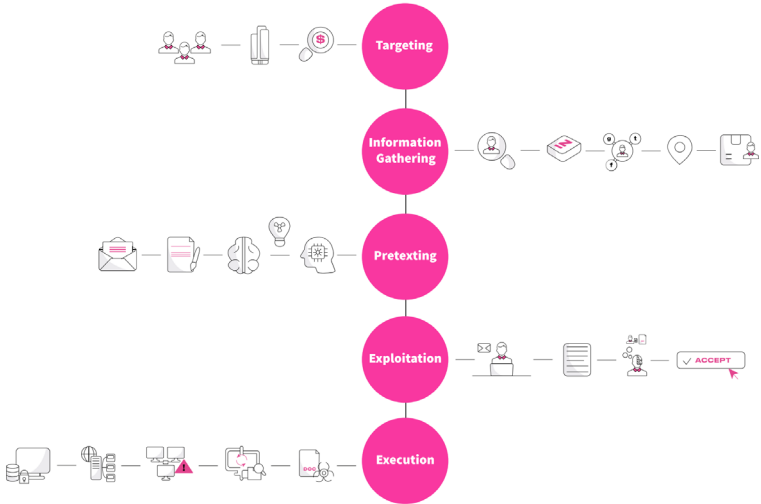


It still works because it targets the one component you cannot patch: human trust.

The Five Stages of an Attack

A social engineering engagement is a kill chain — each step sets up the next:

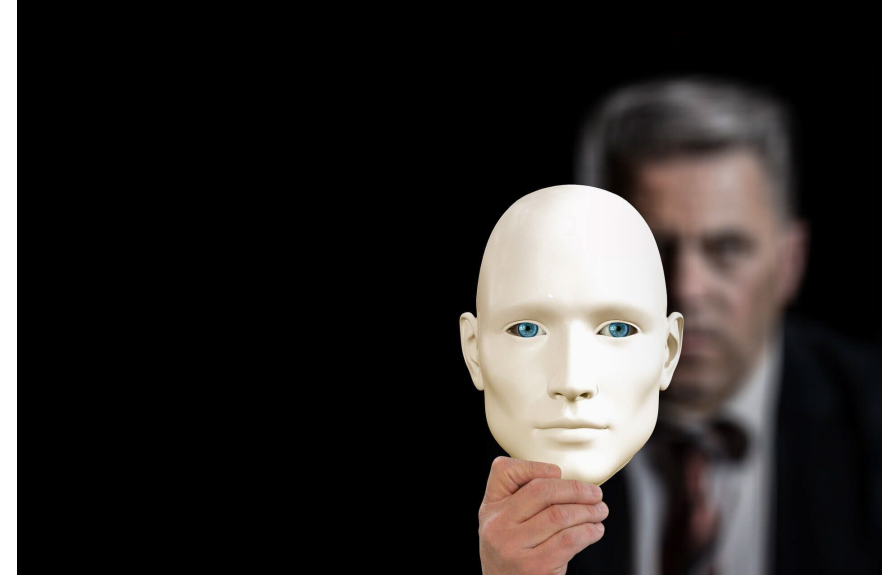
Stage	What happens
Targeting	Pick a company and the employees who are the easiest way in
Info gathering	OSINT and recon: social media, forums, in-person scouting
Pretexting	Invent a scenario and build trust without raising suspicion
Exploitation	Use that trust to get credentials, data, or a foot in the door
Execution	Achieve the goal: exfiltration, a planted implant, a compromise



Kevin Mitnick: A Case Study

In the 1990s, Mitnick stole the source code to Motorola's MicroTAC phone — with a phone.

- Called directory assistance, then worked through eight call transfers to map the org.
- Impersonated a research-center employee to get an internal extension.
- Manipulated an employee into **zipping the source code** and sending it over FTP.
- No exploit, no malware — just trust, patience, and a good pretext.

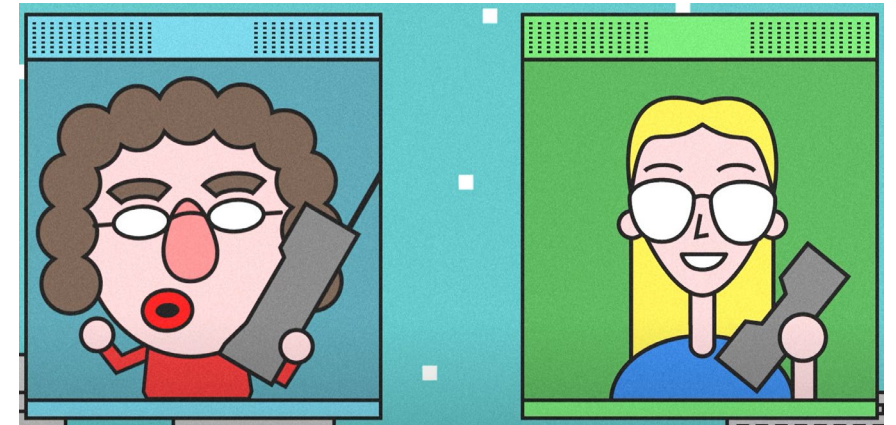


Social engineering leading to theft — the attack that needs no vulnerability.

Vishing: Attacks Over the Phone

Vishing is voice phishing — manipulating a target over a phone or conferencing tool.

- The attacker adopts a **role** — help desk, a vendor, an executive — and a reason to call.
- Urgency does the work: a problem that must be solved **now** short-circuits verification.
- Common asks: reset a password, read back a code, approve access, confirm details.
- The same playbook runs over Zoom, Teams, and Discord, not just the phone.



Hackers, 1995

Common Techniques

The in-person toolkit — most of these need nothing but nerve and a good story:

Technique	What it is
Impersonation	Posing as a new hire, tech support, repair crew, or delivery driver
Pretexting	The invented reason behind the impersonation — the lie, and how elaborate it is
Eavesdropping	Listening in on conversations without approval
Shoulder surfing	Reading passwords, PINs, or badge numbers over someone's shoulder
Dumpster diving	Digging through the trash for documents, org charts, and hardware
Vishing	Voice phishing over a phone or conferencing tool

LESSON 2

Pretexting & Physical Assessments



Building a Pretext

A pretext is the story you tell — in a physical engagement it is the most important thing you build.

- **Appearance and props** — a pizza box, hi-vis vest, or fake badge does more work than words.
- **Anticipated questions** — know what you'll be asked and have the answer ready first.
- **A reason to say yes** — make the ask time-based and emotional so hesitation feels costly.
- **Depth** — backstory, an accent, a supervisor's name; each layer buys another question.



The real test

A pretext succeeds or fails on how many questions it can absorb before you run out of a good answer. That is what you'll measure against a partner in the lab.

Physical Testing Is Still Social Engineering

The tools get you to the door; the pretext gets you through it — and permission keeps you out of jail.

- Physical assessments span Wi-Fi, doors, badges, and lock security.
- The moment you must interact with a person, you are back to pretexting.
- Scope defines what is in bounds — which buildings, systems, and methods.



SECURITY FOCUS

Always get written authorization: a signed contract with the client and any third parties, plus a physical get-out-of-jail letter to show police or security.

Why it matters: Without it, a physical engagement is just trespassing — and you are the one arrested.

Overt vs. Covert Assessments

Overt

- You are not hiding the test
- Staff know an assessment is happening
- You openly probe doors, locks, and controls
- Answers whether controls physically hold up



darknetdiaries.com/episode/67

Covert

- You are under cover
- Staff do not know it is a test
- Tests detection and human response, not just locks
- Depends heavily on **pretext** and stealth

Either way: the value of a physical test is what it reveals about people and process, not just about hardware.

LESSON 3

The Attacker's Toolkit



Bypassing Doors & Locks

A deliberately unglamorous kit — the point is to open a door quietly, not to look like a spy.

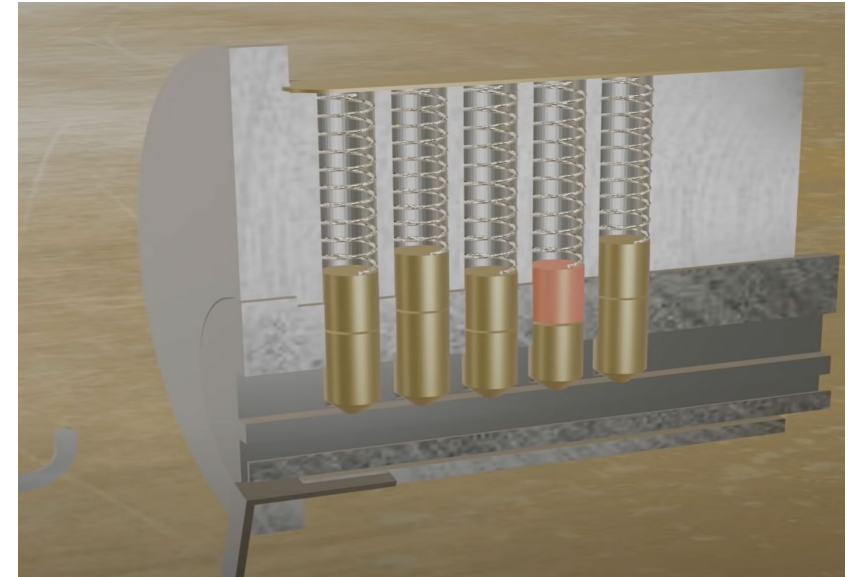
- **Lock picks** — manipulate the pins of a pin-tumbler lock to turn it without the key.
- **Shove-it tool** — slides into the jamb, works around the latch, and shims the door.
- **Under-the-door tool** — reaches under to catch and pull a lever handle from inside.
- **Gate bypass** — exploits motion and request-to-exit hardware that unlock from the safe side.



How Lock Picking Works

A pin-tumbler lock opens when every pin stack rises exactly to the shear line:

- Each pin stack has a **key pin** and a **driver pin** split at the shear line.
- A **tension wrench** applies slight rotation; a pick lifts pins one at a time.
- Set each pin at the shear line and it stays put — when all are set, the plug turns.
- A **padlock** is the easiest place to learn; Sparrows picks are the class favorite.



LIVE DEMO

Demo the shove-it tool, then pick a padlock — fastest to open the master lock wins.

Network Implants (Hak5)

Given a few seconds of physical access, these implants blend in and do the rest:

Device	What it does
LAN Turtle	Inline Ethernet man-in-the-middle; hands the attacker a remote shell
Packet Squirrel	Advanced inline MITM capture and VPN-based remote access
Bash Bunny	Emulates USB devices; runs staged attacks (QuickCreds) in seconds
WiFi Pineapple	Rogue access point that lures clients and intercepts traffic



Hak5 makes a whole catalog — every one assumes the attacker is already inside.

Rogue USB & Keystroke Injection

If a device says it's a keyboard, it's a keyboard — and every computer trusts it automatically.

- **USB Rubber Ducky** — looks like a flash drive, types payloads at superhuman speed.
- **DuckyScript** — a few lines can open a shell, grab a hash, or pull a payload.
- **Bash Bunny** — adds Ethernet, storage, and serial to chain several attacks.
- **Staged payloads** — pull the real attack from the network so it can unplug in seconds.



LIVE DEMO

Plug in a Rubber Ducky and watch it type a payload in the seconds a target looks away.

Getting In With People

The easiest control to defeat is a helpful employee holding a door:

- **Tailgating** — slip through a controlled door behind someone without their knowledge.
- **Impersonation** — look the part so an employee holds the door for you on purpose.
- Once inside, a rogue USB or network implant only needs a moment of unattended access.



LESSON 4

Defense & Mitigation



Defending as an Individual

When you're the one being worked, slow it down and make the pretext do the proving:

- **Stonewalling** — don't give up information easily, however routine the request sounds.
- **Verify identity** — confirm through a different channel: callback, email, or in person.
- **Gather intelligence** — string them along; you may learn who you're really dealing with.
- **Ask your own questions** — company, tenure, employee ID; see if the pretext holds.
- **Wrong number / location** — end the interaction and report it to your security team.

Training, Testing & the SE CTF

A trained, skeptical workforce turns the weakest link into a sensor network:

- Regular **employee training** and **phishing / pretext testing** build the reflex to pause.
- Educate users on the attacks **currently** circulating, not last decade's.
- Report-and-investigate culture: one flagged call can protect the whole org.



Watch: DEF CON SE CTF

Contestants social-engineer real companies live on stage. As you watch, ask: which of today's defense tactics would have stopped each call?

Physical Mitigations

No single control is enough — physical security is layers that each buy time and attention:

- **Gated entrance, fencing, lighting** — funnel visitors and remove the shadows.
- **Alarms, sensors, CCTV** — raise an alert and record the evidence.
- **Mantraps** — admit one authenticated person at a time; defeat tailgating.
- **Air-gapping** — keep the crown jewels off any network a plugged-in implant can reach.



The Motion-Detection Door

A concrete example of a control that backfires — and how to fix it:

- Many doors unlock on any inside motion via a **request-to-exit (REX)** sensor.
- A can of **compressed air** sprayed under the door triggers the sensor and pops it open.
- Fix: shield or reposition the REX sensor, or require a door-position sensor plus a badge.



The Human Is the Attack Surface

Every technique in this unit routes through the same weakness:



SECURITY FOCUS

Lock picks, Hak5 implants, and rogue USB devices are all downstream of one thing: a person who granted access, held a door, or plugged something in. The perimeter is defended by technology; the **trust** is defended by trained people.

Why it matters: You can harden every door in the building and still lose to one helpful employee.

Live Demo: Rogue USB

A benign keystroke-injection demo — the point is speed and trust, not a real payload.

- Show the device: it looks and mounts like an ordinary flash drive.
- Plug it into the target; it enumerates as a **keyboard** in about a second.
- Watch it type a `DuckyScript` payload far faster than any human.
- Debrief: this is why "just plug it in to see what's on it" is dangerous.



Same trust the Bash Bunny abuses — the target sees a keyboard and obeys.

Hands-On Lab

Lab 1 is graded and presented next week; Lab 2 runs in class.

- **Lab 1 — Create a Pretext** to enter the data center in room T111.
- Write the pretext with props, clothing, and reasoning; anticipate the challenge questions.
- Pair off and test it — count how many questions it survives before it breaks, then present.
- **Lab 2 — Lock Picking**: learn the pin-tumbler, try the bypass tools, and pick a padlock.



A pretext is graded on how many questions it absorbs; the lock, on whether it opens.

Key Takeaways



Social engineering targets human trust — the one component you can't patch.



A pretext lives or dies on how many questions it can absorb.



Picks, Hak5 implants, and rogue USB all assume a few seconds of physical access.



Computers trust keyboards absolutely — that's the whole keystroke-injection attack.



Defense is trained, skeptical people backed by layered physical controls.

MID-STATE TECHNICAL COLLEGE · IT PROGRAMS

Questions?

Unit 6 · Social Engineering: Physical Attacks